

Informe profesional de pentesting

Actividad A08 — Hacking Ético | Laboratorio Basic Pentesting

Cliente académico: INSECUR S.A. • Facultad de Informática y Diseño — Universidad Champagnat

Campo	Registro
Estudiante	Valentino Farrando
Usuario GitHub / branch	Valenfarra / farrando-valentino
Usuario público TryHackMe	valenfarra
Correo	valenfarra@gmail.com
Laboratorio	TryHackMe — Basic Pentesting (basicpentestingjt)
Fecha de ejecución documentada	7 al 9 de octubre de 2026
Fecha de cierre técnico	9 de octubre de 2026
DNI / legajo	DNI: 46.235.437 Legajo: 31782371
Estatus del room	Acceso root demostrado; respuestas de la sala pendientes de cargar y validar en TryHackMe

Estado del documento: borrador académico para revisión y posterior incorporación al repositorio. No se incluyen contraseñas recuperadas, claves privadas ni hashes de autenticación.

1. Resumen ejecutivo

Se realizó una evaluación de seguridad exclusivamente sobre las instancias efímeras asignadas por TryHackMe al laboratorio Basic Pentesting. Se identificaron seis puertos TCP abiertos, recursos SMB de consulta anónima y un directorio web con documentación interna accesible. La secuencia documentada permitió obtener acceso SSH como jan, pasar a la cuenta kay mediante una clave privada indebidamente legible y su passphrase recuperada, y ejecutar comandos autorizados de comprobación como root por medio de sudo. Asimismo, se verificó una lectura de WEB-INF/web.xml a través de AJP compatible con Ghostcat (CVE-2020-1938).

Los resultados corresponden a un entorno de entrenamiento; el impacto operativo sobre una organización real es hipotético y se presenta como escenario de continuidad, no como un incidente ocurrido en producción.

2. Pre-pentesting

2.1 Alcance, autorización y exclusiones

Alcance: únicamente la sala Basic Pentesting y las IP privadas asignadas dinámicamente por TryHackMe durante las sesiones (entre otras, 10.66.178.58, 10.66.181.134, 10.66.138.179 y 10.66.141.140). El cambio de IP obedece al reinicio de las máquinas; los hallazgos corresponden al mismo laboratorio de formación. No se evaluaron terceros, redes externas ni sistemas de INSECUR S.A. en producción.

2.2 Reglas de enfrentamiento (ROE)

Pruebas limitadas al host asignado y al tiempo de vida de cada sesión; enumeración de servicios, validaciones de vulnerabilidades y comprobaciones de privilegios sin alterar datos de producción. Se evitó publicar credenciales o material criptográfico. Se efectuaron pruebas de diccionario contra SSH únicamente en el entorno autorizado. Los

límites de tráfico y horario no fueron definidos específicamente por la guía; se aplicaron límites de concurrencia durante las pruebas de autenticación.

2.3 Metodología

Se siguió una secuencia compatible con PTES y con la estructura provista por la guía A08: preparación y alcance, reconocimiento, escaneo, enumeración, explotación, post-explotación y reporte. La clasificación de riesgos se expresa cualitativamente; no se presentan puntuaciones CVSS calculadas, ya que no se dispone de datos suficientes para asignarlas con rigor.

3. Inventario de exposición y metodología aplicada

Puerto	Servicio identificado	Evidencia
22/tcp	OpenSSH 8.2p1 Ubuntu	nmap_inicial.txt
80/tcp	Apache HTTP Server 2.4.41	gobuster.txt
139/tcp	NetBIOS / Samba	enum4linux.txt
445/tcp	SMB / Samba 4.15.13-Ubuntu	enum4linux.txt
8009/tcp	AJP/1.3	nmap_servicios_adicionales.txt
8080/tcp	Apache Tomcat 9.0.7	nmap_servicios_adicionales.txt

Herramientas y justificación: Nmap (descubrimiento y caracterización), Gobuster (enumeración de rutas HTTP), smbclient y Enum4linux (recursos y cuentas SMB), curl (respuestas HTTP), Hydra (auditoría de autenticación SSH), Searchsploit (localización de PoC), script Ghostcat adaptado a Python 3 (validación controlada), ssh2john y John the Ripper (evaluación offline de protección de claves), SSH/sudo (verificación de identidades y privilegios).

```

kali@kali: ~/basic-pentesting
Session Actions Edit View Help
| http-enum:
|_ /development/: Potentially interesting directory w/ listing on 'apache/2.4.41 (ubuntu)'
139/tcp open  netbios-ssn
445/tcp open  microsoft-ds

Host script results:
|_ samba-vuln-cve-2012-1182: Could not negotiate a connection:SMB: ERROR: Server returned less data
than it was supposed to (one or more fields are missing); aborting [9]
|_ smb-vuln-ms10-054: false
|_ smb-vuln-ms10-061: Could not negotiate a connection:SMB: ERROR: Server returned less data than i
t was supposed to (one or more fields are missing); aborting [9]

Nmap done: 1 IP address (1 host up) scanned in 74.14 seconds

(kali@kali)-[~/basic-pentesting]
$ nmap -p- -T3 -oN bitacora/nmap_todos_puertos.txt 10.66.181.134
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-08 13:45 -0400
Stats: 0:26:33 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 47.43% done; ETC: 14:41 (0:29:23 remaining)
Stats: 0:26:36 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 47.48% done; ETC: 14:41 (0:29:22 remaining)
Stats: 0:26:36 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 47.49% done; ETC: 14:41 (0:29:23 remaining)
Stats: 0:26:43 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 47.61% done; ETC: 14:41 (0:29:21 remaining)
Stats: 0:26:44 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 47.62% done; ETC: 14:41 (0:29:21 remaining)
Nmap scan report for 10.66.181.134
Host is up (0.18s latency).
Not shown: 65490 closed tcp ports (reset), 39 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
8009/tcp   open  ajp13
8080/tcp   open  http-proxy

Nmap done: 1 IP address (1 host up) scanned in 4468.55 seconds

(kali@kali)-[~/basic-pentesting]
$

```

Figura 1. Escaneo TCP completo: seis puertos abiertos.

4. Hallazgos técnicos

H-01 — Listado de directorio y divulgación de notas internas

Campo	Registro
Severidad estimada	Media
Fase	Reconocimiento / HTTP
Descripción / validación	Se accedió a /development/ y a dev.txt y j.txt, que exponen notas de desarrollo, referencias a Apache Struts y advertencias de credenciales débiles. La mención a Struts 2.5.12 no demuestra que esa versión esté ejecutándose.
Categoría	CWE-548 (posible exposición de información por listado).
Impacto CIA	Confidencialidad: facilitar reconocimiento y ataques posteriores.
Salvaguarda propuesta	Deshabilitar listado de directorios, retirar notas de

	desarrollo de la raíz web y restringir acceso.
Evidencia	evidencias/reconocimiento/ 04_directorio_development.png, 05_archivo_dev.png y 06_archivo_j.png
Riesgo residual	Bajo a medio tras remediación verificable; requiere nueva prueba

H-02 — Acceso anónimo a recurso SMB

Campo	Registro
Severidad estimada	Media
Fase	Enumeración / SMB
Descripción / validación	La consulta sin credenciales identificó y permitió leer el recurso Anonymous y descargar staff.txt. El archivo expone nombres de empleados; no se demostró permiso de escritura.
Categoría	CWE-732 (permisos potencialmente insuficientes).
Impacto CIA	Confidencialidad: información interna accesible sin autenticación.
Salvaguarda propuesta	Eliminar acceso anónimo no requerido, aplicar ACL por grupos y revisar periódicamente recursos compartidos.
Evidencia	evidencias/reconocimiento/07_smb_recursos.png, 08_smb_anonymous.png y 09_staff.png
Riesgo residual	Bajo a medio tras remediación verificable; requiere nueva prueba

H-03 — Política de contraseñas insuficiente

Campo	Registro
Severidad estimada	Media
Fase	Enumeración / SMB
Descripción / validación	Enum4linux reportó longitud mínima de cinco caracteres y complejidad deshabilitada. Esta información describe una política expuesta por Samba; no demuestra por sí sola que cada cuenta use credenciales débiles.
Categoría	CWE-521 (política de contraseñas débiles).
Impacto CIA	Confidencialidad: aumenta probabilidad de adivinación.
Salvaguarda propuesta	Fortalecer longitud y controles de credenciales comprometidas, MFA donde corresponda y limitación de intentos.
Evidencia	bitacora/enum4linux.txt
Riesgo residual	Bajo a medio tras remediación verificable; requiere nueva prueba

H-04 — Lectura de archivo interno vía AJP / Ghostcat

Campo	Registro
Severidad estimada	Alta
Fase	Explotación controlada / AJP
Descripción / validación	Tomcat 9.0.7 y AJP 8009 estuvieron expuestos. Una PoC de Ghostcat adaptada a Python 3 recuperó el contenido de WEB-INF/web.xml a través del protocolo AJP. Esto confirma lectura indebida de ese archivo; no se demostró ejecución remota de código.
Categoría	CVE-2020-1938.
Impacto CIA	Confidencialidad: exposición de configuración interna; impactos adicionales no validados.
Salvaguarda propuesta	Actualizar Tomcat a versión corregida soportada; deshabilitar AJP si no se usa o limitarlo a interfaces internas y revisar secretos y configuración.
Evidencia	evidencias/explotacion/15_ghostcat_xml.png; bitácora local ghostcat_resultado.txt (no publicada)
Riesgo residual	Bajo a medio tras remediación verificable; requiere nueva prueba

H-05 — Contraseña débil permite acceso SSH como jan

Campo	Registro
Severidad estimada	Alta
Fase	Explotación inicial / SSH
Descripción / validación	Auditoría controlada con Hydra halló credencial válida para jan en un conjunto posterior del diccionario; se estableció sesión SSH y whoami/id confirmaron UID 1001.
Categoría	CWE-521 / CWE-307 (contextual).
Impacto CIA	Confidencialidad e integridad: acceso interactivo no autorizado a cuenta.
Salvaguarda propuesta	Rotar credenciales, adoptar claves o MFA, bloquear contraseñas comunes, limitar intentos y monitorear autenticación.
Evidencia	evidencias/explotacion/16_acceso_jan.png; evidencia de Hydra sensible, no publicar
Riesgo residual	Bajo a medio tras remediación verificable; requiere nueva prueba

H-06 — Clave SSH privada de kay legible por otros usuarios

Campo	Registro
Severidad estimada	Alta

Fase	Post-explotación / permisos
Descripción / validación	La clave /home/kay/.ssh/id_rsa tenía permisos 644 y Jan confirmó acceso de lectura. Con ssh2john/John se recuperó su passphrase mediante análisis local y se confirmó acceso como kay. Los secretos no se incorporan al informe.
Categoría	CWE-732 / CWE-522.
Impacto CIA	Confidencialidad e integridad: suplantación de kay desde una cuenta comprometida.
Salvaguarda propuesta	Revocar y reemplazar clave expuesta; establecer permisos 600 en la clave y 700 en .ssh, revisar propietarios y controles de acceso.
Evidencia	evidencias/post/17_permisos_clave_kay.png, 18_id_rsa_permisos.png y 21_kay_grupos.png
Riesgo residual	Bajo a medio tras remediación verificable; requiere nueva prueba

H-07 — Credencial almacenada en archivo de respaldo

Campo	Registro
Severidad estimada	Alta
Fase	Post-explotación / datos sensibles
Descripción / validación	En /home/kay/pass.bak se observó una contraseña en texto plano. Su utilización permitió ejecutar sudo -l; la pertenencia de kay al grupo sudo autorizó (ALL : ALL) ALL. sudo whoami y sudo id confirmaron ejecución con UID 0. La presencia de un archivo legible por otros usuarios agrava la exposición.
Categoría	CWE-256 / CWE-522 (credenciales sin protección).
Impacto CIA	Confidencialidad, integridad y disponibilidad: posibilidad de administrar completamente el sistema.
Salvaguarda propuesta	Eliminar el secreto del respaldo, rotarlo, limitar sudo al mínimo necesario, restringir permisos y buscar copias adicionales.
Evidencia	evidencias/post/22_archivo_backup.png y 23_sudo_root_evidencia.png
Riesgo residual	Bajo a medio tras remediación verificable; requiere nueva prueba

5. Resumen ejecutivo de hallazgos

Severidad cualitativa	Cantidad	Identificadores
Crítica	0	—
Alta	4	H-04, H-05, H-06, H-07
Media	3	H-01, H-02, H-03

Baja	0	—
Total	7	H-01 a H-07

Las severidades son estimaciones académicas y requieren validación de exposición y controles compensatorios antes de usarlas en una evaluación real. El acceso root quedó confirmado mediante sudo, pero no se realizó modificación persistente del sistema.

```
(kali@kali)-[~/basic-pentesting]
$ python3 ~/basic-pentesting/ghostcat.py -p 8009 -f WEB-INF/web.xml 10.66.138.179
Getting resource at ajp13://10.66.138.179:8009/asdf

<?xml version="1.0" encoding="UTF-8"?>
<!--
Licensed to the Apache Software Foundation (ASF) under one or more
contributor license agreements.  See the NOTICE file distributed with
this work for additional information regarding copyright ownership.
The ASF licenses this file to You under the Apache License, Version 2.0
(the "License"); you may not use this file except in compliance with
the License.  You may obtain a copy of the License at

    http://www.apache.org/licenses/LICENSE-2.0

Unless required by applicable law or agreed to in writing, software
distributed under the License is distributed on an "AS IS" BASIS,
WITHOUT WARRANTIES OR CONDITIONS OF ANY KIND, either express or implied.
See the License for the specific language governing permissions and
limitations under the License.
-->
<web-app xmlns="http://xmlns.jcp.org/xml/ns/javaee"
  xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
  xsi:schemaLocation="http://xmlns.jcp.org/xml/ns/javaee
    http://xmlns.jcp.org/xml/ns/javaee/web-app_4_0.xsd"
  version="4.0"
  metadata-complete="true">
  <display-name>Welcome to Tomcat</display-name>
  <description>
    Welcome to Tomcat
  </description>
</web-app>
```

Figura 2. Lectura de WEB-INF/web.xml a través de AJP.

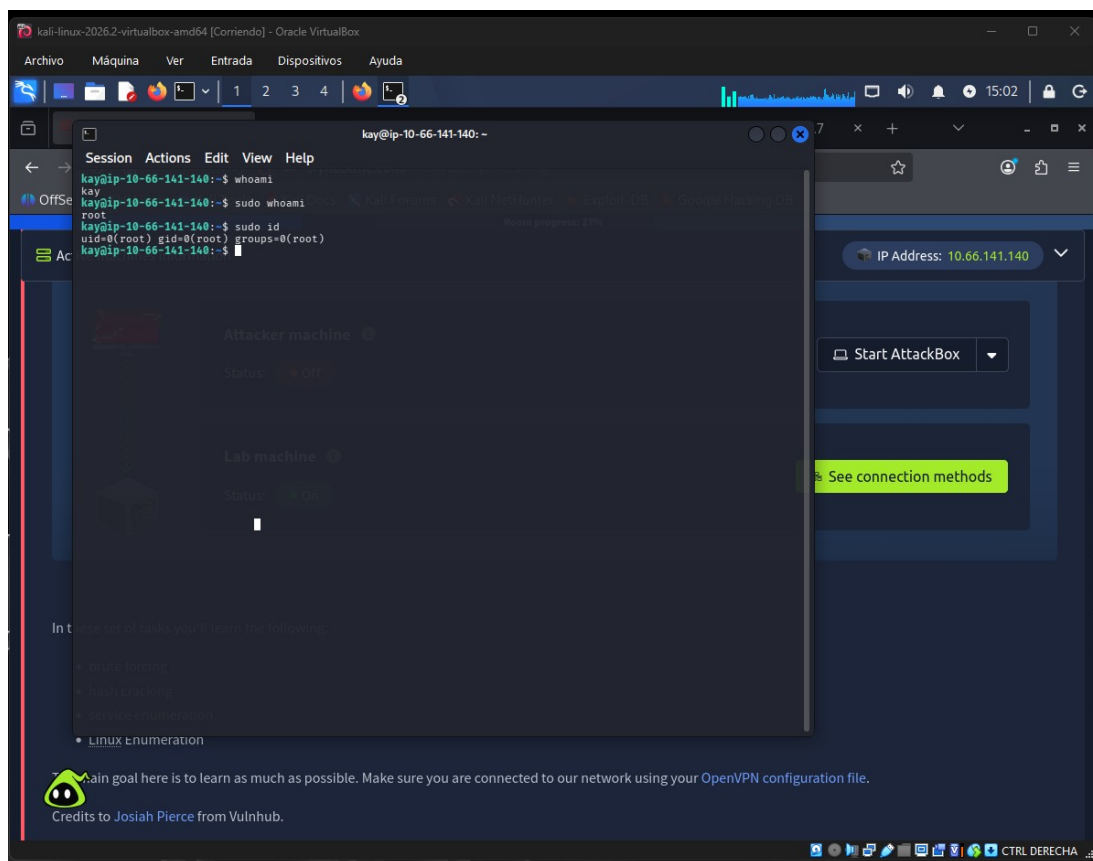


Figura 3. Validación de privilegios root mediante sudo.

6. Post-pentesting: recomendaciones

6.1 Técnicas

Prioridad inmediata: rotación de contraseñas y claves comprometidas, revisión y eliminación de respaldos con credenciales, reducción de facultades sudo y actualización de Tomcat/AJP. Prioridad alta: corregir los permisos de archivos SSH, proteger los recursos SMB y retirar la documentación interna del servidor web. Prioridad continua: centralizar logs de autenticación, monitorear intentos fallidos, aplicar revisiones de configuración y realizar una nueva validación tras las correcciones.

6.2 Administrativas

Formalizar política de identidades y secretos, registro de cambios, clasificación de información, procedimientos de baja y rotación de accesos, capacitación a desarrolladores y responsables de infraestructura, y auditorías técnicas periódicas autorizadas.

7. Protocolo de contingencia — escenario hipotético

7.1 Escenario e impacto

Escenario propuesto: detección de acceso no autorizado a una cuenta SSH que aprovecha credenciales débiles, clave privada expuesta y permisos excesivos, con posible acceso root. En una empresa hipotética, el evento podría afectar la integridad de aplicaciones, la confidencialidad de datos y la disponibilidad de servicios. No ocurrió un incidente de esta clase en INSECUR S.A. durante el TP.

Fase	Acción propuesta
Activación	Alertas de autenticación anómala, uso inesperado de sudo o lecturas de archivos sensibles; apertura formal de incidente y preservación de evidencia.
Contención (primeros 15 min)	Aislar acceso de red al host comprometido, suspender sesiones y credenciales sospechosas, restringir AJP y congelar logs sin borrarlos.
Recuperación	Restaurar desde imagen validada o reconstruir equipo; instalar versión soportada, rotar secretos, corregir permisos y probar accesos antes de producción.
Comunicación	Notificar a seguridad, infraestructura, responsables del servicio y dirección; evaluar obligaciones regulatorias según tipo de dato afectado.
Post-mortem	Reconstrucción cronológica, causas raíz, revisión de controles, lecciones aprendidas y pruebas de regresión.

RTO estimado (objetivo hipotético): 4 horas para restituir un servicio prioritario mediante restauración prevalidada. RPO estimado: 1 hora de posibles datos perdidos según frecuencia de respaldos. Son supuestos de planificación académica, no compromisos de INSECUR S.A.; deben ajustarse a análisis de impacto y dependencias reales.

8. Anexos y trazabilidad

Anexo A — Bitácoras: bitacora/nmap_inicial.txt, nmap_todos_puertos.txt, nmap_servicios_adicionales.txt, nmap_ajp.txt, nmap_vulnerabilidades.txt, ssh_algoritmos.txt, gobuster.txt y enum4linux.txt. Archivo nmap_inicial.txt conservado con su nombre original.

Anexo B — Evidencias: 23 capturas en evidencias/reconocimiento, evidencias/escaneo, evidencias/explotacion y evidencias/post. Antes de publicar, revisar cada imagen por secretos y comprobar que el usuario público de THM resulte visible donde exige la guía. Algunas capturas no cumplen simultáneamente identidad, IP y fecha/hora; se recomienda incorporarlas como conjunto probatorio con explicación.

Anexo C — Flags: no se aportaron flags ni sus hashes SHA-256; completar únicamente si el laboratorio las exige y luego de obtenerlas. No se deben inventar.

Anexo D — Declaración ética (para firma): Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

Firma: _____ Fecha: _____

9. Fuentes y referencias

Guía + Plantilla A08 — INSECUR S.A., Actividad A08 Hacking Ético (material aportado por la cátedra).

README.md — Repositorio UCHSeguridad2026/TP_THM: trabajo exclusivo en branch personal; no crear Pull Request.

TryHackMe, sala Basic Pentesting: <https://tryhackme.com/room/basicpentestingjt>

Material técnico generado durante la práctica: salidas de Nmap, Gobuster, Enum4linux y evidencias gráficas incluidas en la rama local.

Referencias externas de contraste recomendadas antes de la entrega: Apache Tomcat Security Advisories para CVE-2020-1938; OWASP Web Security Testing Guide; NIST SP 800-115. Estas referencias no sustituyen la evidencia del laboratorio.